

Informe de Pentesting

Actividad A08 — INSECUR S.A.

Agustín Clavijo

October 8, 2026

Contents

1	Datos generales	2
2	Pre-pentesting	2
3	Durante: Hallazgos por fase	3
4	Resumen ejecutivo de hallazgos	8
5	Post-pentesting: Recomendaciones	8
6	Protocolo de Contingencia	8
7	Anexos	9

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Agustín Clavijo
DNI	46060907
Username TryHackMe	agustinclavijo12
Email institucional	agustinclavijo12@gmail.com
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	clavijo-agustin
Fecha de inicio	07/10/2026
Fecha de cierre	08/10/2026

2. Pre-pentesting

Alcance del trabajo

El trabajo se limitó exclusivamente a los entornos de laboratorio de TryHackMe asignados en la guía de la cátedra: las salas **Pentesting Fundamentals** y **Basic Pentesting** (núcleo obligatorio), y la sala de elección **Vulniversity** (Nivel 2). Quedó fuera de alcance cualquier sistema, red o servicio ajeno a las máquinas virtuales provistas por la plataforma TryHackMe dentro de la VPN asignada.

Reglas de Enfrentamiento (ROE)

Se trabajó únicamente contra las direcciones IP asignadas dinámicamente por TryHackMe en cada sesión de VPN. No se realizaron ataques de denegación de servicio. Las pruebas de fuerza bruta (Hydra) se limitaron a los servicios SSH de las máquinas asignadas, sin exceder el tráfico razonable para no afectar la infraestructura compartida de la plataforma. Ante cualquier comportamiento anómalo del entorno, se reinició la sesión de VPN y/o la máquina objetivo según lo indicado por la propia plataforma.

Autorización

Declaro que contaba con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar las actividades de hacking ético descritas en este informe, exclusivamente sobre los entornos de laboratorio de TryHackMe indicados en la guía de la Actividad A08.

Metodología utilizada

Se siguió un flujo metodológico alineado a las fases clásicas de un pentest profesional (en línea con PTES y NIST SP 800-115): reconocimiento, escaneo de puertos y servicios, enumeración, explotación, post-explotación/escalada de privilegios y reporte. En cada máquina se partió de

un escaneo de puertos con Nmap, seguido de enumeración de servicios específicos (SMB, HTTP, SSH) y explotación dirigida según la superficie de ataque identificada.

3. Durante: Hallazgos por fase

Campo	Valor
ID del hallazgo	H-01
Fase	Explotación
Sala	Basic Pentesting
Descripción	Credencial SSH débil del usuario jan , obtenida mediante ataque de fuerza bruta con Hydra contra el servicio SSH usando el diccionario rockyou.txt .
Componente afectado	Servicio SSH (OpenSSH), cuenta jan
Categoría (OWASP / CWE)	CWE-521 (Weak Password Requirements)
CVE (si aplica)	N/A
CVSS estimado	Alto (~7.5)
Evidencia	<code>hydra -l jan -P rockyou.txt ssh://10.67.191.138 → password: armando</code>
Herramienta utilizada	Hydra
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Política de contraseñas robustas (mínimo 12 caracteres, complejidad), bloqueo de cuenta tras intentos fallidos (fail2ban), preferir autenticación por clave sobre contraseña en SSH.
Riesgo residual tras aplicar	Bajo
Campo	Valor

ID del hallazgo	H-02
Fase	Enumeración
Sala	Basic Pentesting
Descripción	Recurso compartido Samba (Anonymous) accesible sin autenticación, que permitió listar y leer archivos internos, revelando nombres de usuario válidos y, eventualmente, la clave privada SSH de kay .
Componente afectado	Servicio Samba/SMB
Categoría (OWASP / CWE)	CWE-284 (Improper Access Control)
CVE (si aplica)	N/A
CVSS estimado	Medio (~6.5)
Evidencia	<code>smbclient //10.67.191.138/Anonymous -N</code>
Herramienta utilizada	<code>smbclient</code>
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar acceso anónimo (<code>null session</code>) en Samba, requerir autenticación para todos los recursos compartidos, auditar permisos periódicamente.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-03
Fase	Explotación
Sala	Basic Pentesting
Descripción	La clave privada SSH de kay estaba protegida por una passphrase débil, crackeada offline con John the Ripper usando <code>rockyou.txt</code> en menos de un segundo.

Componente afectado	Clave privada SSH (<code>kay_id_rsa</code>)
Categoría (OWASP / CWE)	CWE-521 (Weak Password Requirements)
CVE (si aplica)	N/A
CVSS estimado	Medio (~5.9)
Evidencia	<code>ssh2john kay_id_rsa > kay_hash.txt;</code> <code>john --wordlist=rockyou.txt kay_hash.txt → passphrase: beeswax</code>
Herramienta utilizada	ssh2john, John the Ripper
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Exigir passphrases robustas para claves privadas, rotación periódica, considerar MFA para accesos SSH críticos.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-04
Fase	Post-explotación
Sala	Basic Pentesting
Descripción	El usuario <code>kay</code> tenía permiso <code>sudo</code> sin restricciones ((<code>ALL : ALL</code>) <code>ALL</code>), permitiendo escalar a root de forma inmediata.
Componente afectado	Configuración de <code>sudoers</code>
Categoría (OWASP / CWE)	CWE-250 (Execution with Unnecessary Privileges)
CVE (si aplica)	N/A
CVSS estimado	Crítico (~9.8)
Evidencia	<code>sudo -l → (ALL : ALL) ALL; sudo su → whoami = root</code>

Herramienta utilizada	sudo (nativo)
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Aplicar principio de mínimo privilegio en sudoers : otorgar solo comandos específicos necesarios, nunca ALL:ALL salvo cuentas de administración estrictamente controladas.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-05
Fase	Explotación
Sala	Vulniversity
Descripción	El formulario de carga de archivos en /internal/ validaba el tipo de archivo únicamente por extensión (lista blanca: .phtml), sin verificar el contenido real. Esto permitió subir una reverse shell PHP renombrada con extensión .phtml , interpretada igualmente por Apache/PHP.
Componente afectado	internal/index.php (Apache 2.4.41 + PHP)
Categoría (OWASP / CWE)	CWE-434 (Unrestricted Upload of File with Dangerous Type) / OWASP A04:2021
CVE (si aplica)	N/A
CVSS estimado	Crítico (~9.8)
Evidencia	Fuzzing de extensiones confirmó .phtml como Success ; shell obtenida: uid=33(www-data)
Herramienta utilizada	curl, gobuster, netcat, php-reverse-shell (pentestmonkey)
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad

Salvaguarda propuesta	Validar contenido real del archivo (magic bytes/MIME), no solo extensión; almacenar archivos subidos fuera del directorio web o sin permisos de ejecución; listas blancas estrictas de extensiones inofensivas.
-----------------------	---

Riesgo residual tras aplicar	Bajo
------------------------------	------

Campo	Valor
ID del hallazgo	H-06
Fase	Post-explotación
Sala	Vulnversity
Descripción	El usuario <code>www-data</code> tenía permisos suficientes para crear, vincular y habilitar unidades de <code>systemd</code> sin intervención de root. Se creó un servicio que ejecutaba <code>chmod +s /bin/bash</code> al activarse, otorgando SUID a Bash y permitiendo escalar a root.
Componente afectado	systemd (gestión de servicios)
Categoría (OWASP / CWE)	CWE-269 (Improper Privilege Management)
CVE (si aplica)	N/A
CVSS estimado	Crítico (~9.1)
Evidencia	<code>systemctl link /tmp/root.service; systemctl enable --now /tmp/root.service; bash -p → root</code>
Herramienta utilizada	systemd (nativo), bash
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Restringir permisos de usuarios de servicio sobre <code>systemctl</code> y <code>/etc/systemd/system</code> ; aplicar <code>PrivateTmp</code> , <code>AppArmor</code> /SELinux y contenedores para aislar procesos web.
Riesgo residual tras aplicar	Bajo

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-04, H-05, H-06
Alto	1	H-01
Medio	2	H-02, H-03
Bajo	0	—
Total	6	

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas

1. Deshabilitar autenticación por contraseña en SSH, permitiendo solo autenticación por clave con passphrase robusta (H-01, H-03).
2. Configurar fail2ban o similar para bloquear intentos repetidos de fuerza bruta (H-01).
3. Deshabilitar acceso anónimo (null session) en todos los recursos Samba (H-02).
4. Revisar y corregir la configuración de `sudoers`, eliminando privilegios `ALL:ALL` innecesarios (H-04).
5. Implementar validación real de contenido de archivos subidos (no solo extensión) en el módulo de upload (H-05).
6. Restringir permisos del usuario de servicio web sobre `systemctl` y el directorio de unidades de `systemd` (H-06).

Recomendaciones administrativas

1. Establecer una política formal de contraseñas (longitud mínima, complejidad, rotación) aplicable a todos los usuarios y servicios.
2. Realizar auditorías periódicas de configuración de servicios expuestos (SMB, SSH, web).
3. Capacitar al personal de desarrollo en prácticas seguras de manejo de uploads de archivos (OWASP Top 10).
4. Incorporar revisiones de `sudoers` y privilegios de servicio como parte del proceso de hardening previo a producción.

6. Protocolo de Contingencia

Escenario de falla

Si el filtro de validación de archivos del formulario de upload (hallazgo H-05) fuera reproducido en un sistema de producción real de INSECUR S.A., un atacante podría subir una shell web y ejecutar comandos arbitrarios con los privilegios del servicio web (`www-data`), comprometiendo el servidor por completo, tal como se demostró en el laboratorio.

Impacto sobre la continuidad del negocio

Un compromiso de este tipo afectaría la disponibilidad del servicio web expuesto (posible caída o desfiguración del sitio), la confidencialidad de datos almacenados en el servidor, y podría escalar a otros sistemas internos si existe reutilización de credenciales o configuraciones de privilegios excesivos (como se vio en H-04 y H-06). El tiempo de afectación estimado podría ir de horas (restauración desde backup) a días (si se requiere análisis forense completo).

Plan de respuesta

1. **Activación:** detección mediante monitoreo de integridad de archivos (FIM) o alertas de IDS/WAF ante subida de archivos ejecutables inesperados.
2. **Contención:** aislar el servidor afectado de la red (desconectar o bloquear en el firewall), deshabilitar temporalmente el servicio de upload.
3. **Recuperación:** restaurar el servidor desde el último backup limpio verificado, aplicar los parches de los hallazgos H-04, H-05 y H-06 antes de reconectar.
4. **Comunicación:** notificar a dirección de INSECUR S.A. y al equipo técnico interno; si hubo exposición de datos de clientes, evaluar notificación conforme a normativa vigente.
5. **Post-mortem:** documentar la cadena de explotación real, actualizar este informe con las causas raíz y verificar que las salvaguardas propuestas fueron efectivamente implementadas.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas

RPO (Recovery Point Objective): 24 horas

7. Anexos**Anexo A — Bitácora de comandos**

Archivos `bitacora/clase_09_basicpentesting.txt` y `bitacora/clase_10_vulnversity.txt`, adjuntos en el branch `clavijo-agustin`.

Anexo C — Hashes de las flags obtenidas

```
# Basic Pentesting
root.txt    852afba51134631548962400b2970b958e1a5b3cf52c48ee1433d9930fcb2a21

# Vulnversity
root.txt    cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
user.txt    d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante	Fecha
---	------------------------------